

Seguridad en Sistemas de Información

Comisión: 503

Grupo 07:

Brian Ortigosa - Agustín Tisera - Pedro Camillozzi - Ulises Gimenez -
Marina Panatti - Tomás Lardizábal - Gino Bartolucci

Contexto: Amenazas y Malware

Fuerza Bruta

¿Qué es un ataque de fuerza bruta?

Un ataque de fuerza bruta es una técnica de prueba y error utilizada para descubrir una contraseña, PIN, clave criptográfica u otro secreto. En vez de "saber" la respuesta, el atacante prueba candidatos hasta encontrar uno que el sistema acepte.



Espacio de búsqueda

La cantidad de candidatos posibles que existen.

- **PIN de 4 dígitos:** $10^4 = 10.000$ combinaciones.
- **8 letras minúsculas:** $26^8 = 208.827.064.576$ combinaciones

Ataques relacionados

- **Fuerza bruta pura:** Prueba sistemáticamente una gran cantidad de combinaciones posibles.
- **Ataque de diccionario:** Prioriza palabras, patrones y contraseñas frecuentes.
- **Credential stuffing:** Reutiliza pares usuario/contraseña obtenidos en filtraciones de otros servicios.

Pasos para aplicar Fuerza Bruta

1. **Elegir el objetivo:** Una cuenta, un PIN, un archivo cifrado o hashes filtrados
2. **Generar candidatos:** Combinaciones, palabras frecuentes o credenciales conocidas
3. **Comprobar:** Se verifica si el candidato produce una autenticación o coincidencia
4. **Repetir:** Si falla, se prueba el siguiente candidato. Si coincide, se detiene

Ataque online vs. ataque offline

Online

Se prueba contra el login real del servicio. Limitado por red, servidor, bloqueos, rate limiting, CAPTCHA, MFA

Offline

Se prueba en un equipo controlado por el atacante después de obtener hashes. Limitado principalmente por el algoritmo de hash y el hardware disponible

Prevención

Áreas de enfoque y estrategias

Estrategias populares

Existen varias estrategias de protección contra la fuerza bruta, no todas fueron diseñadas con los mismos propósitos y a su vez, las mismas se combinan en dos niveles:

- **De entrada al sistema**
 - Multi factor authentication (MFAs)
 - Rate limiting
 - Políticas de seguridad y claves
 - CAPTCHAs
 - Honeypot accounts
- **Defensa en la base de datos y servidor**
 - Hashing + Salt & Pepper

Hashing

¿Qué es hashing?

Es un proceso matemático que transforma cualquier tipo o cantidad de datos de entrada (como un texto o un archivo) en una cadena alfanumérica **de longitud fija**.

Existen varios algoritmos matemáticos de hashing, cada uno tiene fortalezas o debilidades en ciertas áreas:

- **Archivos e integridad de datos**
- **Protección de credenciales**
- **Ciberdefensa y detección de amenazas**
- **Firmas digitales**

Propiedades del hashing

- **Determinista:** para una misma entrada, siempre se obtiene exactamente la misma salida
- **Unidireccional:** Es un proceso no reversible, una vez se calculan los datos de entrada no se puede regenerar el valor original
- **Efecto avalancha:** Un cambio insignificante en la entrada genera un cambio radical en el hash resultante
- **Resistencia a las colisiones:** Es extremadamente improbable que dos entradas diferentes, generen el mismo hash

Propiedades del hashing

Ejemplo determinista:

```
agustin@DESKTOP-LN7M0SA:~$ echo -n mismaEntrada | sha256sum
9d4751ac9996fa5e31e22e7e12b2eed22e683e4797763c5353ddf339ee81dd4
agustin@DESKTOP-LN7M0SA:~$ echo -n mismaEntrada | sha256sum
9d4751ac9996fa5e31e22e7e12b2eed22e683e4797763c5353ddf339ee81dd4
```

Ejemplo efecto avalancha y resistencia a colisiones:

```
agustin@DESKTOP-LN7M0SA:~$ echo -n "password123" | sha256sum
ef92b778bafef771e89245b89ecbc08a44a4e166c06659911881f383d4473e94f
agustin@DESKTOP-LN7M0SA:~$ echo -n "password122" | sha256sum
c660725919c1c20945cca28ed9944edaf8f4c6a11310c1024e30bd528d0f6c13
```

Algoritmos populares

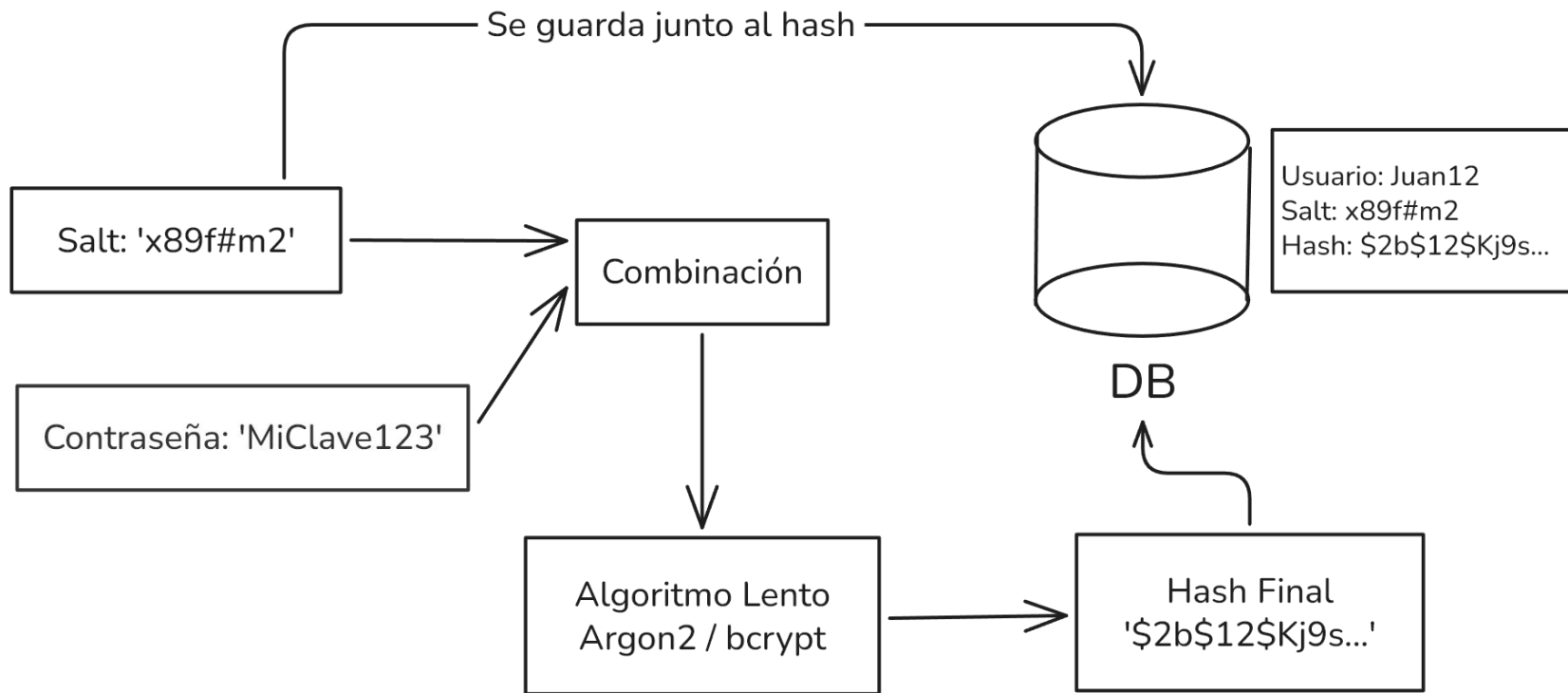
Algunos de los algoritmos populares según su propósito son:

- **bcrypt** y **Argon2**: Mejor para protección de credenciales
- **SHA256**
 - Propósito general
 - Firmas digitales
 - Integridad de archivos
 - Ciberseguridad, detección de malware

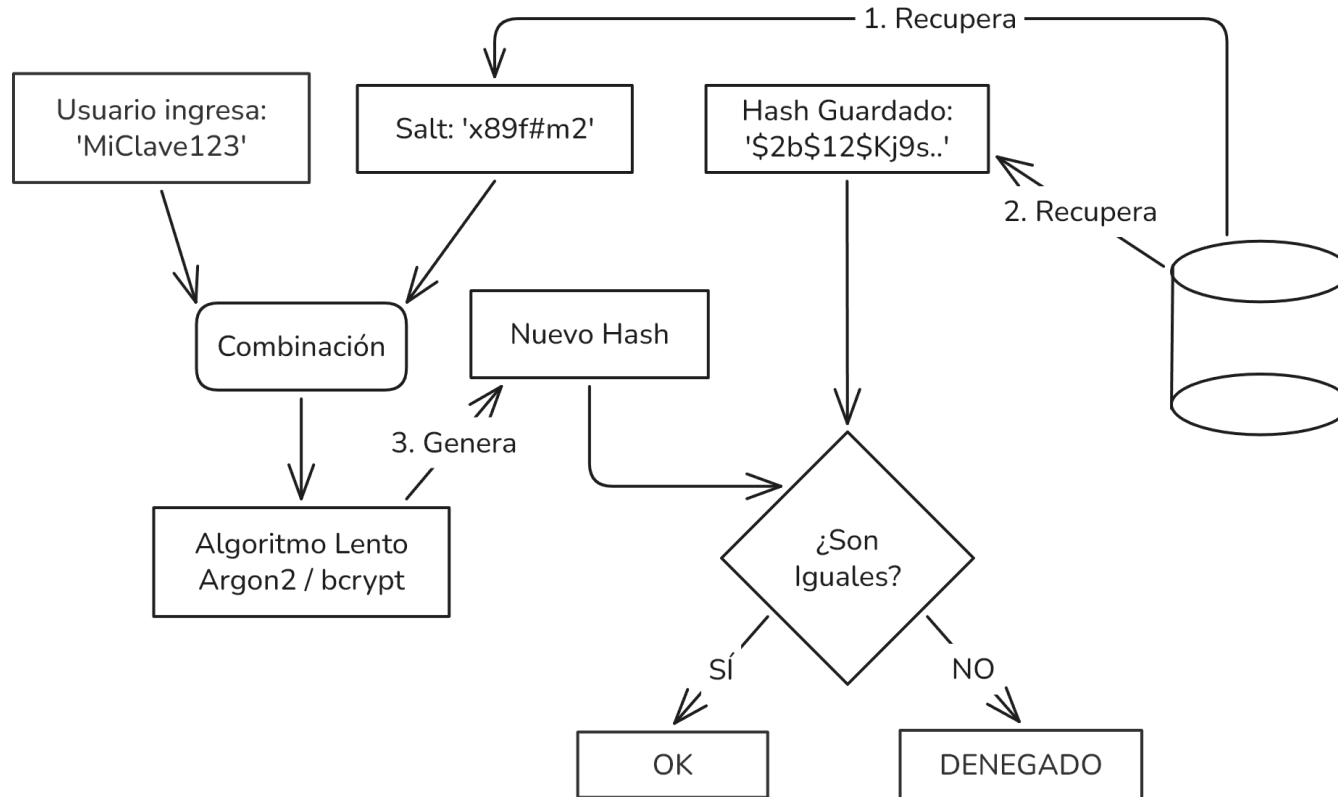
Aclaración

El hashing es comúnmente confundido con el **cifrado**, que en contraste, es un mecanismo **reversible** de transformar la información de manera que sea inteligible para un transporte seguro. Sólo se puede revertir con la llave de cifrado

Almacenamiento y verificación de clave



Almacenamiento y verificación de clave



Salt y pepper

- **Salt:** valor aleatorio, único por contraseña, no secreto. Se guarda junto al hash.
Evita que dos usuarios con la misma clave tengan el mismo hash almacenado
- **Pepper:** secreto único del sistema, almacenado fuera de la base de datos.

La diferencia entre salt y pepper está en dónde se guardan

Salt y pepper

● Salt

● Pepper

¿Es secreto?

No

Sí

¿Único por usuario?

Sí

No, es global al sistema

¿Dónde vive?

Junto al hash

Fuera de la base: HSM, KMS o entorno

¿Qué escenario cubre?

Precálculo y ataque en lote

Robo de la base sin acceso al servidor

Algoritmos lentos

Los más usados: Argon2id, bcrypt, scrypt y PBKDF2

Argon2id

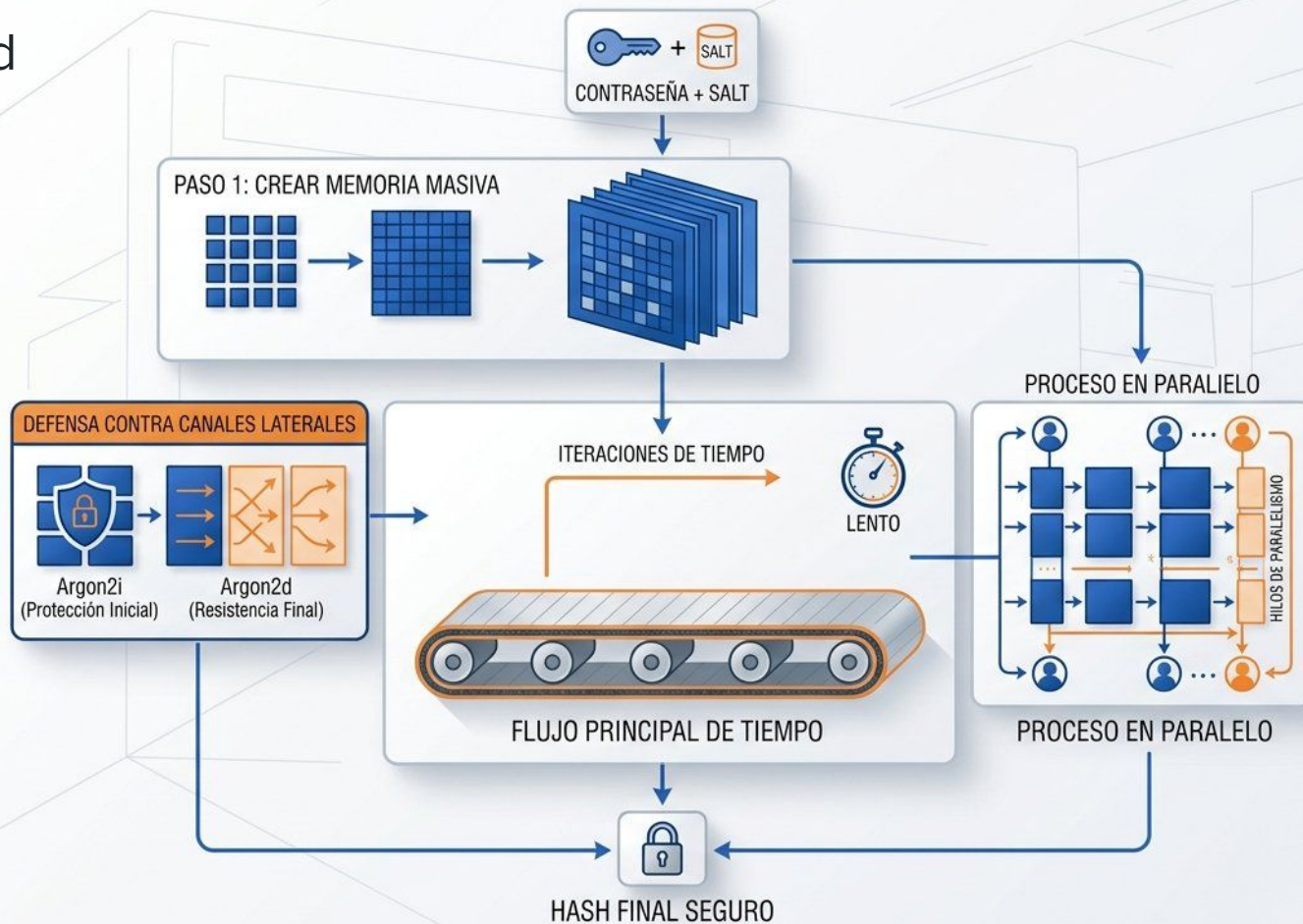
De los cuatro, es el único que permite ajustar el costo en memoria además del de tiempo.

Resistencia a memoria (Memory-hard): Requiere una cantidad importante de memoria RAM para calcular el hash.

Parámetros ajustables: costo de memoria (m_cost), el costo de tiempo (t_cost) y el nivel de paralelismo.

Ganador del PHC 2015 (Password Hashing Competition)

Argon2id



Caso real

Revista científica (2025),
Ataque de fuerza bruta dirigido a panel de administración Wordpress

- ¿Qué pasó?
- ¿Cómo entraron?
- ¿Qué encontramos?
- ¿Qué hicimos?
- ¿Qué cambiamos hicimos?

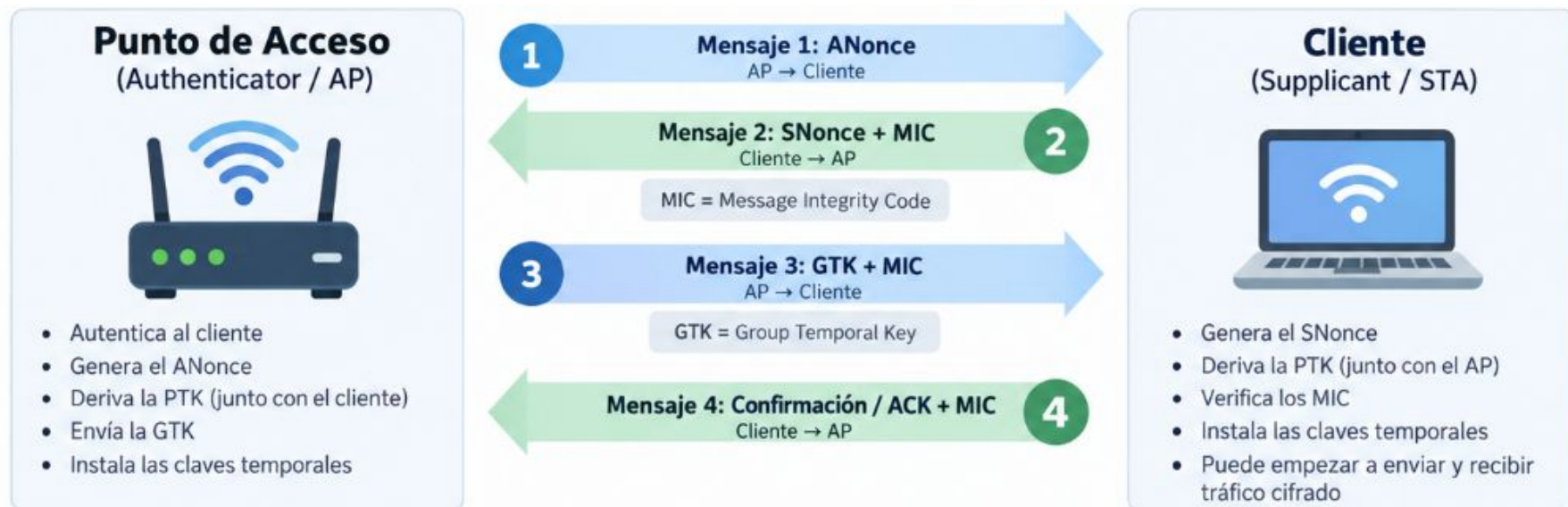
Ataque de Fuerza Bruta Offline

Ejemplo con Wi-Fi:

- ¿Cómo funciona?
 - ¿Qué se busca?
 - Modo monitor y modo managed
 - BSSID (Identificación del punto de acceso), ESSID (Nombre del punto de acceso) y Stations (Dispositivos conectados)

Sigue con el ejemplo de wi-fi

4-way Handshake

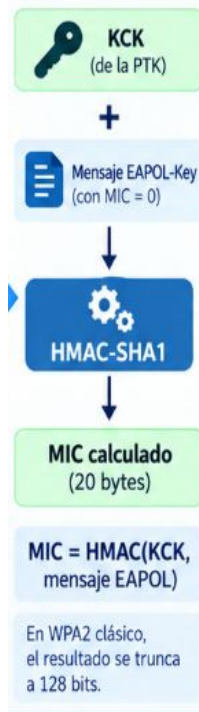


Cómo funciona el MIC

Derivación de la PTK

Ambas partes ya conocen la PMK.

$PTK = PRF(PMK, MAC\ del\ AP, MAC\ del\ Cliente, ANonce, SNonce)$



Aspectos legales y éticos del uso de Fuerza Bruta

- Marco legal en Argentina
- Diferencias entre un pentester y un atacante
- Fuerza bruta no autorizada vs. pentest autorizado

Marco legal en Argentina

Probar credenciales sin permiso puede ser delito, incluso si el ataque no tiene éxito.

Ley 26.388

Sanciona el acceso no autorizado a sistemas y datos informáticos aún sin que el ataque llegue a completarse

Ley 25.326 (protección de datos personales)

Exige a quien administra datos personales a adoptar medidas de seguridad, ya que su exposición por un ataque exitoso agrava la responsabilidad

Convenio de Budapest (Argentina se adhirió en 2018)

Marco internacional que muchos países usan como base legal y para cooperar en investigaciones de delitos informáticos transfronterizos

Clave: estas normas aplican tanto a un desconocido como a un compañero de estudio o trabajo ya que probar sin permiso las credenciales de un sistema ajeno, aunque sea “solo para ver si funciona”, encuadra en la Ley 26.388.

Pentester vs. atacante

Antes de comparar cómo actúa cada uno, veamos quién es quién.

Atacante

Persona que prueba credenciales o explota vulnerabilidades sin autorización del propietario del sistema, buscando acceso, datos o un beneficio propio.

Autorización: ninguna

Objetivo: explotar lo que encuentra

Pentester

Profesional de seguridad que, con autorización explícita y un alcance definido, prueba las defensas de un sistema para encontrar debilidades.

Autorización: explícita, por escrito

Objetivo: encontrar debilidades para corregirlas

Los dos pueden usar exactamente la misma técnica, la fuerza bruta. La única frontera entre uno y otro es la autorización.

¿Qué debe tener esa autorización?

No alcanza con un permiso informal. Un pentestester autorizado se apoya en cuatro elementos concretos.

1

Alcance por escrito

Qué sistemas, cuentas o rangos están habilitados para probarse y además qué queda fuera del alcance.

2

Autorización firmada

Por quien tiene la potestad real sobre el sistema, no un permiso informal intermedio.

3

Ventana acordada

Fechas, horarios y un protocolo de contacto por si algo sale mal durante la prueba.

4

Reporte responsable

Los hallazgos se informan en forma confidencial, no se explotan ni se divulgan sin permiso.

IMPORTANTE: sin un documento firmado por quien tiene la potestad real, “sólo estaba probando” sigue siendo un acceso no autorizado, sin importar la intención.

Fuerza bruta no autorizada vs. pentest autorizado

Fuerza bruta no autorizada

Autorización: Inexistente, informal o asumida por el atacante.

Objetivo: Obtener acceso, datos para un beneficio propio.

Con lo encontrado: Se explota, se vende o se oculta.

Pentest autorizado

Autorización: Contrato o alcance firmado antes de empezar.

Objetivo: Evaluar la seguridad del sistema para corregirla (de ser necesario).

Con lo encontrado: Se reporta de forma confidencial y queda documentado.

Además de la responsabilidad penal de quien ataca, quien administra un sistema puede tener responsabilidad civil o administrativa si no aplicó controles estándar (rate limiting, MFA, hashing seguro).

La fuerza bruta no es legal ni ilegal en sí misma: lo que la define es la autorización.

Conclusiones — De qué se aprovecha

La fuerza bruta no rompe nada: **prueba y verifica. Funciona cuando falla** una de estas tres cosas:

- **Espacio de búsqueda chico**

PIN de 4 dígitos = 10.000 combinaciones (segundos)

Cada carácter extra multiplica, no suma

- **Contraseñas predecibles o reutilizadas**

Diccionario, password spraying, credential stuffing

Si apareció en otra filtración, no se adivina: se copia

- **Sistema que deja probar sin límite**

Online: sin rate limiting ni bloqueos

Offline: hashes con algoritmo rápido (SHA-256) = millones de pruebas/seg

Conclusiones — Cómo se previene

Defensa por capas: cada capa tapa uno de los tres huecos.

- **Ataque online** → controlar cantidad y velocidad
Rate limiting · bloqueos progresivos · CAPTCHA · MFA
- **Ataque offline** → hacer cara cada prueba
Salt único · Argon2id en vez de SHA-256 · work factor creciente · pepper aparte

Caso revista científica 2025: no había límite de intentos → botnet entró en ~2 semanas. Fail2ban + CAPTCHA + bloqueo geográfico fueron estas mismas capas, pero puestas después de restaurar backup y rotar credenciales.

Poner las capas antes cuesta menos que limpiar el incidente después.

Por parte del usuario

Todo lo anterior es responsabilidad del sistema. Pero hay tres cosas que dependen de cada persona, no de ningún servidor:

- **Contraseña única por sitio**

Evita que credential stuffing use una filtración para entrar a otra cuenta

Un gestor de contraseñas hace esto manejable

- **MFA activado en las cuentas importantes**

Correo, banco, accesos administrativos

Adivinar la contraseña deja de alcanzar- Passkey si el servicio la ofrece

Elimina directamente la contraseña compartida que se puede adivinar

Que filtren una contraseña tuya no debería significar que te abren todo lo demás.

Gracias por escuchar.
